

Александр Чаркин
*Куратор специальных
проектов корпоративной
практики ЮК ЭБР*

Персональные данные: как составить соглашение, которое устроит РКН

КТО Я?



Чаркин Александр

*Куратор специальных проектов
корпоративной практики ЮК ЭБР*

Сопровождаю IT-проекты с 2020

Среди проектов:

- Крупнейший производитель технологий для БЛА (~1 млрд руб)
- AI-стартап, который впоследствии был выкуплен лидирующим банком
- Защита команды, занимающейся разработкой smart-contract решений, от претензий недобросовестного заказчика

Помимо этого:

- 2 красных диплома, сейчас в процессе защиты диссертации
- 3 ДПО, в том числе в сфере legaltech и AI
- Благодарности от ГД, комментарии в федеральных СМИ

00

Почему это важно

Базовые штрафы: ст. 13.11 КоАП РФ

Норма	Нарушение	Юрлицо	Повторно
ч. 1	Обработка без правового основания либо несовместимая с целями сбора	150–300 тыс.	300–500 тыс.
ч. 2	Обработка без письменного согласия там, где оно обязательно	300–700 тыс.	1–1,5 млн
ч. 3	Нет политики в открытом доступе	30–60 тыс.	—
ч. 4	Не предоставлена информация субъекту об обработке его данных	40–80 тыс.	—
ч. 5	Не исполнено требование об уточнении, блокировании или уничтожении	50–90 тыс.	300–500 тыс.
ч. 8	Нарушение требования о локализации	1–6 млн	6–18 млн
ч. 10	Не подано уведомление об обработке персональных данных	100–300 тыс.	—
ч. 11	Не подано уведомление об утечке	1–3 млн	—

Суммы указаны для юридических лиц. Для граждан и должностных лиц действуют самостоятельные размеры. ИП по ч. 8–18 отвечают как юрлица

Оборотные штрафы за утечки

Объём утечки	Штраф на юридическое лицо	
1–10 тыс. субъектов или 10–100 тыс. идентификаторов	3–5 млн руб.	ч. 12
10–100 тыс. субъектов или 100 тыс. – 1 млн идентификаторов	5–10 млн руб.	ч. 13
более 100 тыс. субъектов или более 1 млн идентификаторов	10–15 млн руб.	ч. 14
любой объём специальных категорий персональных данных	10–15 млн руб.	ч. 16
любой объём биометрических персональных данных	15–20 млн руб.	ч. 17

**Повторная утечка: от 1 до 3% совокупной выручки за год,
но не менее 20 млн руб. (для спецкатегорий и биометрии — 25 млн) и не более 500 млн руб.**

ч. 15 и 18 ст. 13.11 КоАП РФ. Идентификатор — уникальное обозначение сведений о физлице в информационной системе оператора

Уголовная ответственность: ст. 272.1 УК РФ

Незаконное использование, передача, сбор и хранение компьютерной информации с персональными данными, если она получена незаконным путём

Наказание по частям статьи

- ч. 1 — штраф до 300 тыс. руб. или до 4 лет лишения свободы
- ч. 2 — с использованием служебного положения, до 5 лет
- ч. 3 — группой лиц по предварительному сговору, до 6 лет
- ч. 4 — тяжкие последствия, до 8 лет
- ч. 5 — специальные категории данных, до 10 лет

Что это значит для стартапа

- Субъект — физическое лицо, чаще всего ваш собственный или бывший сотрудник
- Компания при этом получает административный штраф за то, что не приняла мер защиты
- Минимальный набор мер: NDA, разграничение доступа, логирование выгрузок, отзыв доступов при увольнении

01

Что такое персональные данные?

Персональные данные: определение

Любая информация, относящаяся к прямо или косвенно определённомu или определяемому физическому лицу (субъекту персональных данных)

п. 1 ст. 3 Федерального закона от 27.07.2006 № 152-ФЗ

Три вывода, которые важнее самого определения

- Закон не содержит закрытого перечня. Персональными данными является всё, что позволяет выйти на конкретного человека — прямо или в совокупности с другими сведениями.
- Отсутствие Ф.И.О. ничего не решает. Идентификатор без имени (хеш, cookie, ID заказа) остаётся персональными данными, если по нему можно выделить человека.
- Оценка совокупности. Один MAC-адрес — не ПД. MAC-адрес плюс геолокация и cookie — уже ПД.

Почему это касается любого стартапа

Обязанности оператора возникают не с выручкой, а с первым же e-mail в форме на сайте

Вы уже оператор, если:

- на сайте есть форма обратной связи или подписки
- вы наняли первого сотрудника или подрядчика-физлицо
- в продукте есть регистрация пользователя
- вы ведёте CRM или базу лидов
- вы используете Яндекс.Метрику или иную аналитику

Что это значит на практике:

- подать уведомление в Роскомнадзор до начала обработки
- иметь правовое основание на каждую цель обработки
- опубликовать политику и назначить ответственного
- хранить данные россиян в базах на территории РФ

Что практика относит к персональным данным

Файлы cookie

Постановление мирового судьи по делу № 5-1176/2023

Адрес электронной почты

Письмо Минцифры России от 17.03.2022 № П25-5623-ОГ

Данные Яндекс.Метрики и Google Analytics

Письмо Минцифры России от 12.05.2025 № П25-44929

История заказов даже без Ф.И.О. — основа для профилирования

Семинар Роскомнадзора от 26.11.2020

Хеш-ID с историей запросов и просмотров для адресной рекламы

13 ААС от 01.07.2016 по делу № А56-6698/2016

Информация о соединениях и трафике абонента без его имени

9 ААС от 23.05.2016 по делу № А40-14902/16

Само по себе не относится

MAC-адрес устройства. Но в совокупности с геолокацией или cookie он становится персональными данными.

Главный критерий

Если совокупность данных необходима и достаточна для идентификации лица — это персональные данные (АС МО от 30.03.2023 по делу № А40-139096/2022).

Категории персональных данных

Обычные

Ф.И.О., контакты, должность, история покупок. Базовый режим обработки.

Специальные

Раса, национальность, политические взгляды, убеждения, здоровье, интимная жизнь. Обработка запрещена, кроме исчерпывающего перечня случаев (ст. 10).

Биометрические

Данные, характеризующие физиологические особенности и позволяющие установить личность. Требуют письменного согласия (ст. 11).

Разрешённые субъектом для распространения

Отдельное согласие по форме Приказа Роскомнадзора от 24.02.2021 № 18.
Несоблюдение формы = отсутствие согласия.

Общедоступные

Формируются только с письменного согласия.

Публикация данных в соцсети не делает их общедоступными автоматически.

Что закон считает «обработкой»

Любое действие с персональными данными — с автоматизацией или без неё

сбор · запись · систематизация · накопление · хранение · уточнение (обновление, изменение) · извлечение · использование · передача (распространение, предоставление, доступ) · обезличивание · блокирование · удаление · уничтожение

Различайте два способа передачи

- Распространение — раскрытие неопределённому кругу лиц
- Предоставление — раскрытие определённому лицу или кругу лиц

Удаление ≠ уничтожение

При удалении данные исключаются из системы, но носитель сохраняется. Уничтожение делает восстановление невозможным и подтверждается актом и выгрузкой из журнала регистрации событий.

Ответ Минцифры России от 07.05.2024 № П25-11679-ОГ

02

Оператор и обработчик: кто есть кто

Оператор и обработчик: два разных статуса

Оператор

Лицо, самостоятельно или совместно с другими организующее и (или) осуществляющее обработку персональных данных, а также определяющее цели обработки, состав данных и совершаемые с ними действия.

п. 2 ст. 3 Закона о персональных данных

Обработчик

Лицо, осуществляющее обработку персональных данных по поручению оператора. Самостоятельной цели обработки у него нет.

ч. 3 ст. 6 Закона о персональных данных

Что важно про статус оператора

- Ключевой признак — вы определяете цель обработки
- Статус не зависит от размера бизнеса, штата и оборота
- Статус нельзя «передать» подрядчику договором

Что важно про статус обработчика

- Действует строго в рамках поручения оператора
- С 2023 года тоже подаёт уведомление в Роскомнадзор
- Начал использовать данные в своих целях — стал самостоятельным оператором со всеми обязанностями

Поручение на обработку: что должно быть в договоре

Обязательные условия

- Перечень действий с персональными данными
- Цели обработки
- Обязанность соблюдать конфиденциальность
- Обязанность обеспечивать безопасность данных при обработке
- Требования к защите обрабатываемых данных
- Срок обработки и порядок уничтожения либо возврата данных

О чём забывают чаще всего

- Указать обработчика в согласии субъекта — его наименование и адрес
- Запретить или урегулировать субпоручение (подрядчик подрядчика)
- Прописать порядок уведомления оператора об инциденте — ваши 24 часа начинают течь с момента, когда узнали вы
- Получить заверения о законности сбора, если данные приходят к вам от третьего лица

Кто перед кем отвечает

**Перед субъектом персональных данных отвечает оператор
— даже если виноват подрядчик**

Оператор

- Отвечает перед субъектом за действия обработчика
- Обязан выбрать обработчика, способного обеспечить безопасность
- Уведомляет Роскомнадзор об утечке, в том числе произошедшей у подрядчика

Обработчик

- Отвечает перед оператором — в объёме, который вы пропишете в договоре
- С 2022 года иностранный обработчик отвечает и перед субъектом

«Доводы жалобы о невиновности Учреждения в неправомерном доступе к персональным данным своих сотрудников, который произошёл через доступ злоумышленника к инфраструктуре подрядной организации, не обеспечившей защиту этих данных, несостоятельны»

Постановление Верховного Суда РФ от 21.01.2026 № 5-АД25-119-К2

03

Основания обработки и требования к согласию

Шесть оснований обработки, которые нужны стартапу

- | | | |
|-----------|--|---|
| 01 | Согласие субъекта | Роскомнадзор рассматривает его как основной способ легитимировать обработку |
| 02 | Исполнение договора с субъектом | Или заключение договора по его инициативе |
| 03 | Исполнение обязанностей в силу закона | Кадровый учёт, бухгалтерия, налоговая отчётность |
| 04 | Законные интересы оператора или третьих лиц | Если не нарушаются права и свободы субъекта |
| 05 | Защита жизни и здоровья субъекта | Когда получить согласие невозможно |
| 06 | Научные и статистические исследования | При обязательном обезличивании |

ч. 1 ст. 6 Закона о персональных данных. Согласие не «сильнее» других оснований — но именно его проще всего проверить и оспорить

Пять требований к согласию

Конкретность

Согласие должно вытекать из понятных явных действий человека, а не из молчания или бездействия

Информированность

До дачи согласия субъект имеет всю информацию о том, как его данные будут обрабатываться

Сознательность

Согласие обдуманное, как результат полноценного волеизъявления

Свобода

Нельзя понуждать к даче согласия — человек действует в своих интересах

Однозначность

Нельзя получить согласие «мимоходом» в рамках другого действия человека

Если Роскомнадзор сочтёт, что согласие не отвечает хотя бы одному требованию, это означает, что надлежащего правового основания у оператора не было никогда.

Отдельное согласие: правило с 1 сентября 2025 года

Согласие на обработку персональных данных оформляется отдельно от иных информации и документов, которые подписывает субъект

Позиция Роскомнадзора

- Требование не соблюдается при включении согласия в пакет документов, в том числе при подписании электронной подписью
- Нужно подтвердить факт ознакомления субъекта с согласием и его принятие

Комментарий РКН от 27.08.2025

Цена вопроса

- Граждане — до 15 тыс. руб.
- Должностные лица — до 300 тыс. руб.
- Юридические лица — до 700 тыс. руб.
- Повторно — для юрлиц от 1 до 1,5 млн руб.

ч. 2 и 2.1 ст. 13.11 КоАП РФ

Как правильно сделать форму на сайте

☐ Я даю согласие на обработку персональных данных в соответствии с Политикой

Обязательные условия

- Галочка не предустановлена
- Без галочки форма не отправляется
- Слово «Политика» — гиперссылка на документ в подвале сайта
- Слово «согласие» — гиперссылка на отдельный текст согласия

Соразмерность

Содержание и объём обрабатываемых данных должны соответствовать заявленным целям и не быть избыточными.

Например, если для обратного звонка нужен только телефон — не просите дату рождения и паспорт.

ч. 5 ст. 5 Закона о персональных данных

04

Уведомление Роскомнадзора и документы оператора

Уведомление об обработке: кто подаёт и когда

Оператор обязан уведомить Роскомнадзор до начала обработки персональных данных

ч. 1 ст. 22 Закона о персональных данных

Кто подаёт

- Практически каждый оператор — с 2022 года круг исключений минимален
- Обработчики тоже подают уведомление (позиция РКН от 01.03.2023)
- Не подавать можно, только если обработка ведётся на бумаге без средств автоматизации

Частая ошибка с датой

Дата начала обработки в уведомлении не может быть раньше даты подачи самого уведомления. Указание «задним числом» суды расценивают как нарушение.

Решение Ленинского районного суда г. Перми от 01.08.2025 по делу № 12-633/2025

Уведомление: на что смотрят и чем рискуете

Четыре зоны внимания

- Количество и качество целей обработки. Цели должны индивидуализировать именно вашу компанию
- Организационные, правовые и технические меры. Берутся из ст. 18.1 и 19
- Сведения об обеспечении безопасности. Основа — Постановление Правительства РФ от 01.11.2012 № 1119
- Состав базы данных. Отсутствие облака выглядит нереалистично

Тест на плохое уведомление

- Целей всего 5–10
- По целям невозможно отличить IT-компанию от завода
- Консультант готовил уведомление, не изучая специфику деятельности

Штраф за неподачу или просрочку: граждане 5–10 тыс., должностные лица 30–50 тыс., юрлица 100–300 тыс. руб. (ч. 10 ст. 13.11 КоАП). При первом нарушении, отсутствии вреда и оперативном исправлении суды заменяют штраф предупреждением.

Базовый пакет документов оператора

Политика в отношении обработки персональных данных

Публикуется в открытом доступе, для сайта — в подвале

Приказ о назначении ответственного за организацию обработки

Плюс должностная инструкция ответственного

Локальные акты об обработке и защите данных

Правила доступа, перечень ИСПДн, модель угроз, перечень мест хранения

Формы согласий по каждой цели

Отдельно от прочих документов, с 01.09.2025

Договоры поручения с обработчиками

И соглашения о передаче с другими операторами

Журналы и акты уничтожения

Акт об уничтожении плюс выгрузка из журнала регистрации событий

Политика обработки персональных данных

Что должна содержать

- Сведения об операторе: наименование и контакты
- Цели и основания обработки
- Перечень обрабатываемых данных и категории субъектов
- Порядок и условия обработки, включая передачу третьим лицам
- Сроки хранения
- Права пользователей и порядок их реализации
- Меры по защите персональных данных

ст. 18.1 Закона о персональных данных

Признак плохой политики

Её составлял человек, который читал только закон,
— и она подходит любой компании в стране.

Штраф за отсутствие политики в открытом доступе

- Граждане — 1,5–3 тыс. руб.
- Должностные лица — 6–12 тыс. руб.
- ИП — 10–20 тыс. руб.
- Юридические лица — 30–60 тыс. руб.

ч. 3 ст. 13.11 КоАП РФ

Чек-лист аудита сайта

☐	Cookie и метрические системы	Проверьте, что реально устанавливается на страницах, и сверьтесь с текстом политики
☐	Плашка cookie-баннера	Две равнозначные кнопки и реальное управление загрузкой счётчиков
☐	Все точки сбора данных	Формы обратной связи и заявок, регистрация, личный кабинет, новости с фото, раздел «команда»
☐	Соразмерность полей	Каждое поле формы должно быть обосновано целью обработки
☐	Политика в подвале сайта	Плюс отдельная действующая ссылка на текст согласия
☐	Раздел «команда» и фото сотрудников	Требуется отдельное согласие на распространение по форме Приказа РКН от 24.02.2021 № 18

05

Локализация и трансграничная передача

Локализация: что должно остаться в России

Персональные данные граждан РФ должны «осесть» в базе на территории России и только после этого могут передаваться иностранному лицу

Действия, подлежащие локализации

- Запись
- Систематизация
- Накопление
- Хранение
- Уточнение (обновление, изменение)
- Извлечение

Пример

Пользователь из России регистрируется в приложении и указывает e-mail и телефон. Сначала эти данные сохраняются на сервере в России — и только потом могут уйти, например, в иностранный сервис аналитики.

**Штраф: юрлица 1–6 млн руб.,
повторно 6–18 млн руб. (ч. 8 и 9 ст. 13.11 КоАП)**

Регуляторы подтверждают: локализация не запрещает трансграничную передачу и не распространяется на данные, полученные не от субъектов, а от третьих лиц (разъяснения РКН от 24.03.2025 № 08-134789, Минцифры от 12.05.2025 № П25-44929)

Трансграничная передача: что это и когда возникает

Передача персональных данных на территорию иностранного государства органу власти, иностранному физическому или иностранному юридическому лицу (ст. 3 152-ФЗ)

Да, это ТГП (иностранное лицо имеет доступ)

- Использование Google Analytics
- Использование иностранных онлайн-сервисов
- Передача данных дочерней компании за рубежом
- Хранилища Dropbox, Google Drive
- Использование иностранного ИИ

Нет, это не ТГП

- Передача данных своему филиалу или представительству за рубежом
- Работники российской компании работают удалённо
- Использование удалённого рабочего стола

Три позиции регуляторов, о которых чаще всего спрашивают

- Канал в мессенджере, к которому субъекты присоединяются по ссылке-приглашению, под определение ТГП не подпадает (ответ ЦА РКН от 14.12.2023 № 08-145976)
- Работа на виртуальной машине за рубежом не является ТГП: передачи иностранному лицу не происходит (позиция Минцифры)
- Если обработчик передаёт данные за рубеж по вашему поручению — уведомляет оператор, а не обработчик

Уведомление о ТГП: когда подавать и что решит Роскомнадзор

Нужно

- Систематическая деятельность с конкретным государством — постоянный контрагент, сервис, инфраструктура

Не нужно

- Разовая переписка по почте с контрагентом
- Подключение к звонку в Zoom или Google Meet
- Бронирование отеля сотруднику

Сроки рассмотрения

- 10 рабочих дней на решение по уведомлению
- Плюс 10 и 5 рабочих дней, если Роскомнадзор направит запрос и получит ответ

Роскомнадзор запретит передачу, если

- Получатель не защищает данные и не определены условия прекращения обработки
- Получатель — организация, деятельность которой запрещена или признана нежелательной в РФ
- Передача несовместима с целями сбора

Две процедуры — разные гарантии

Если Роскомнадзор принимает решение сам, он предварительно запрашивает позицию оператора. Если решение принимается по представлению ФСБ, Минобороны или МИД — оператор узнаёт об этом постфактум.

Пять ошибок, которые повторяют почти все

- | | | |
|----|---|---|
| 01 | «Мы ещё маленькие, до нас не дойдут» | Уведомление о начале обработки — самостоятельное нарушение с отдельным штрафом до 300 тыс. руб. Проверка не нужна: отсутствие в реестре видно публично. |
| 02 | Политика и согласие скачаны из интернета | Документ, подходящий любой компании в стране, не описывает ваши реальные процессы. Расхождение документа и практики регулятор увидит сразу. |
| 03 | Согласие «зашиито» в оферту или пакет документов | С 1 сентября 2025 года это прямое нарушение — до 700 тыс. руб. за первый раз. |
| 04 | С подрядчиками нет договоров поручения | Передача данных подрядчику без поручения — обработка без основания. Плюс вы всё равно отвечаете за его утечку перед субъектом. |
| 05 | Нет плана на случай инцидента | 24 часа на уведомление — это меньше, чем срок согласования письма внутри компании. План и ответственный должны существовать заранее. |

Есть вопросы?
alexandr_charkin@mail.ru
@charkin_alexandr

Спасибо за внимание